

Apéndice 3: Informe sobre evaluación y tratamiento de riesgos

1. Proceso de evaluación y tratamiento de riesgos de la información

Todo el proceso de evaluación y tratamiento de riesgos ha sido realizado en conformidad con el documento Proceso de gestión de riesgos 2025.

1.1. Objetivo de la gestión de riesgos

El objetivo de la evaluación de riesgos es identificar escenarios de riesgos con un enfoque basado en eventos, los riesgos aceptables y riesgos residuales.

El objetivo del tratamiento de riesgos es definir medios sistemáticos para disminuir o controlar esos riesgos los cuales serán mitigados en el plan de tratamiento de riesgos. Además, medir la eficacia de los controles implementados.

1.2. Alcance de la gestión de riesgos

La evaluación y tratamiento de riesgos fue realizado a las Unidades de Negocio: Siempresoft ERP y Siempresoft OSE, en conformidad con el **Documento sobre el Alcance del SGSI**.

1.3. Período de tiempo

La evaluación de riesgos fue implementada en el período comprendido entre el 01/02/2025 al 11/08/2025. El tratamiento de riesgos fue implementado en el período comprendido entre el 14/08/2025 al 15/11/2025. Los informes finales fueron elaborados durante el mes de agosto del mismo año.

1.4. Participantes en el proceso y recolección de información

El proceso de evaluación y tratamiento de riesgos fue dirigido por Ana Karim Salazar – Oficial de Seguridad de la Información con el apoyo de los propietarios de los activos:

- Ing. Milton Guevara - Gerente General.
- Elizabeth – Responsable de control de calidad
- Sheyla Quevedo – Jefe de soporte al cliente
- Judith Ballena – Asistente administrativo
- Elio Mondragón - Asistente de Producción
- Fidel Espinoza – Jefe de Consultoría
- Marcelo Vassallo – Desarrollador OSE

Durante la evaluación de riesgos, se evaluó la efectividad de los controles seleccionados y las actividades programadas en el Plan de tratamiento de Riesgos.

1.5. Breve resumen de la metodología aplicada

En resumen, el proceso se realizó de la siguiente manera:

- Se revisaron y aprobación de los activos primarios, propietarios e identificación de nuevos riesgos basado en eventos.
- Identificación de escenarios de riesgos con a partir de las fuentes de riesgo y sus DES.

- Evaluación de la gestión de riesgos por cada ecosistema OSE y PSE
- Incorporación de riesgos detectados de los nuevos proyectos implementados por la organización.
- Incorporación de riesgos detectados a los activos tecnológicos.
- Los riesgos residuales valorados como no aceptables serán tratados con los mismos controles seleccionados.

1.6. Resumen de los documentos utilizados durante el proceso de evaluación y tratamiento de riesgos

Proceso de gestión de riesgos_2025

- Categoría del activo
- Activos primarios: 23 activos
- Activos de soporte: 47 activos
- Identificación de riesgos: 13 escenarios de riesgos (R39 – R51), 10 riesgos no aceptables a tratar (R39, R40, R42, R43, R44, R45, R46, R48, R49, R51).
- Riesgos de Proyectos: 12 escenarios de riesgos, 07 riesgos no aceptables a tratar (PY09, PY13, PY15, PY16, PY17, PY18, PY19).
- Activos tecnológicos: 39 escenarios de riesgo, 13 riesgos no aceptables a tratar (RT4, TR5, RT7, RT9, R10, R17, RT22, RT23, RT25, RT32, RT36, RT37, RT38)
- Plan de tratamiento de riesgos: 18 Controles que serán implementados.

Los escenarios con nivel de riesgo medio contarán con un formulario de Oportunidad de mejora.